Programa de Especialización en Gestión Estratégica y Operativa

Curso: Control Interno Modelo COSO ERM (Enterprise Risk Management)

Inicio: Jueves 29 de Octubre de 2026

Docente: Mag. Mario Miguel Vergara Silva
mvergara@esan.edu.pe

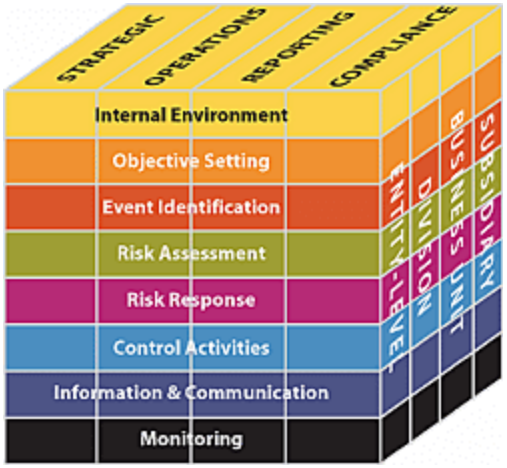
Marco Conceptual y Antecedentes del CONTROL INTERNO

COSO



Ley Sarbanes Oxley

SOX

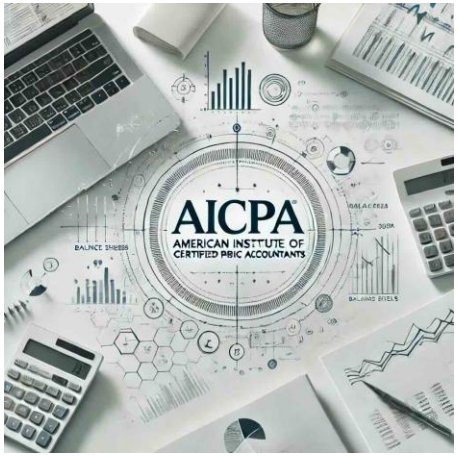


fControles Internos

COBIT

DEFINICION DE “CONTROL INTERNO” – AICPA (1949)

En 1949, el AICPA (American Institute of Certified Public Accountants) definió el control interno de la manera siguiente:



“El control interno comprende el **Plan de Organización** y todos los **Métodos y Procedimientos** que en forma coordinada se adoptan en un negocio para Salvaguardar sus activos, verificar la exactitud y la confiabilidad de su Información financiera, promover la eficiencia operacional y fomentar la adherencia a las políticas prescritas por la administración”

Control Interno en Proyectos









Roles de Control en Proyectos



Rol / Área	Función Principal en el Control de Avance
Control de Proyectos	Medición de avance físico/financiero, desviaciones y pronósticos.
Gerencia de Proyecto (PM)	Gestión integral y toma de decisiones ante desviaciones del plan.
PMO (Corporativo)	Estandarización de métricas y consolidación de reportes.
Gerencia de Obras	Control técnico y avance físico directo en campo.

Control Interno en Proyectos



MODELO DE LAS TRES LÍNEAS DE DEFENSA APLICADO A PROYECTOS

Para lograr un control efectivo sin ahogar la agilidad del proyecto, es crucial implementar el **Modelo de las Tres Líneas de Defensa** (actualizado por el IIA - Instituto de Auditores Internos):

Primera Línea:
Gerencia Operativa del Proyecto (Propietarios del Riesgo)
Diseñan y ejecutan los controles diarios en el frente de trabajo (Project Manager, Ingenieros).

Segunda Línea:
Funciones de Control, Calidad y ERM (Supervisión de Riesgos)
Facilitan metodologías, monitorean el cumplimiento del apetito de riesgo y supervisan el cumplimiento regulatorio/normativo (PMO Corporativa, Oficial de Riesgos, Área Legal).

Tercera Línea:
Auditoría Interna (Aseguramiento Independiente)
Proporciona una evaluación objetiva e independiente sobre la efectividad del diseño y operación de los controles del proyecto directamente al Directorio y Comité de Auditoría.

The Institute of Internal Auditors

AN UPDATE of the Three Lines of Defense

Principios de Gobierno Corporativo del G20 y la OCDE - 2016





La Organización para la Cooperación y el Desarrollo Económico (OCDE, OECD por sus siglas en inglés**)** emitió su primera declaración de principios en **1999** y actualizada en **2004.**

Una segunda revisión que se llevó a cabo en 2014 y 2015, sobre la versión de los Principios de 2004, permitió obtener la versión del **2016**, que se basaba en el común entendimiento de que un alto grado de transparencia, rendición de cuentas, supervisión y respeto a los derechos de los accionistas así como al papel de los principales actores interesados, resultan esenciales para el buen funcionamiento de un sistema de gobierno corporativo.

Aprobación del CODIGO DE BUEN GOBIERNO CORPORATIVO PARA SOCIEDADES PERUANAS - 2013

La Superintendencia del Mercado de Valores (SMV), mediante Resolución N° 012-2014-SMV/01, aprobó el nuevo "Reporte sobre el Cumplimiento del Código de Buen Gobierno Corporativo para las Sociedades Peruanas". El nuevo reporte es aplicado a partir de la presentación de la memoria anual del ejercicio 2014, y para el caso de los prospectos de oferta pública, a partir del 1 de enero del 2015.

La SMV reconoce que la adopción del Código de Buen Gobierno Corporativo para las Sociedades Peruanas es voluntaria, pero obligatoria para las listadas en la BVL.



Estructura

Código de Buen Gobierno Corporativo de las Sociedades Peruana

Pilar I: Derechos de los accionistas
Principio 1: Paridad de trato
Principio 2: Participación de los accionistas
Principio 3: No dilución en la participación en el capital social
Principio 4: Información y comunicación a los accionistas
Principio 5: Participación en dividendos de la sociedad
Principio 6: Cambio o toma de control
Principio 7: Arbitraje para solución de controversias

Pilar II: Junta General de Accionistas
Principio 8: Función y competencia
Principio 9: Reglamento de Junta General de Accionistas
Principio 10: Mecanismos de convocatoria
Principio 11: Propuestas de puntos de agenda
Principio 12: Procedimientos para el ejercicio del voto
Principio 13: Delegación de voto
Principio 14: Seguimiento de acuerdos de Junta General de Accionistas

Pilar III: El Directorio y la Alta Gerencia
Principio 15: Conformación del Directorio
Principio 16: Funciones del Directorio
Principio 17: Deberes y derechos de los miembros del Directorio
Principio 18: Reglamento de Directorio
Principio 19: Directores independientes
Principio 20: Operatividad del Directorio
Principio 21: Comités especiales
Principio 22: Código de Ética y conflictos de interés
Principio 23: Operaciones con partes vinculadas
Principio 24: Funciones de la Alta Gerencia

Pilar IV: Riesgo y Cumplimiento
Principio 25: Entorno del sistema de gestión de riesgos
Principio 26: Auditoría interna
Principio 27: Auditores externos

Pilar V: Transparencia de la información
Principio 28: Política de información
Principio 29: Estados financieros y memoria anual
Principio 30: Información sobre estructura accionaria y acuerdos entre los accionistas
Principio 31: Informe de gobierno corporativo

Principio 22: Código de Ética y CONFLICTOS DE INTERESES

La Empresa adopta medidas para prevenir, detectar, manejar y revelar **conflictos de interés** que puedan presentarse. **El Directorio es responsable** de realizar seguimiento y control de los **posibles conflictos de interés** que surjan en el Directorio.

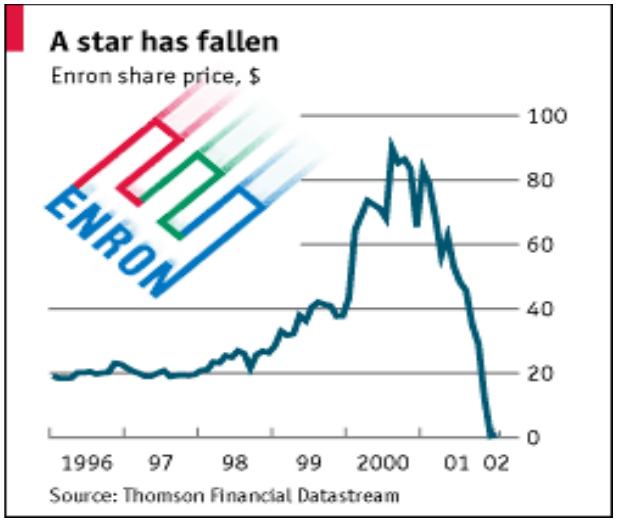




ERNON SCANDAL









Cifras ENRON - 2001	
ENRON	7ma Empresa Ranking FORBES Gigantesca corporación dedicada al negocio de la comercialización de energía
Cotización de la Acción en la Bolsa NY (Enero 2001)	US$ 80 por Acción
Mediados 2001	Rumores prácticas dudosas contables (SPE creadas)
02 de Diciembre 2001	Se Declaró en Quiebra
Trabajadores despedidos de HOUSTON	4,000
Trabajadores despedidos en 40 países del Mundo	21,000
Auditores Externos	ARTHUR ANDERSEN
Las SPE (Sociedades de Propósito Especial)	600 Millones US$ fuera de Balances
Cotización de la Acción en la Bolsa NY (Enero 2002)	US$ 0.67 por Acción



Cifras WORLD COM - 2002	
WORLD COM Operadora estadounidense de telecomunicaciones	Inflado sus cuentas (ganancias) en US$ 4,000 Millones
Despido Laboral	17,000 Empleados que le permitía ahorrar US$ 900 Millones al año.
Auditores Externos	ARTHUR ANDERSEN
Informe de Auditoria 2002	con opinión Limpia o Sin Salvedades
Separación de Directores	Despido de Director Financiero Scott Sullivan y Reununcia de Vicepresidente Tesorero David Myers (primo hermano del socio de Andersen)
Trabajos de Arthur Andersen	Auditores desde 1990 a 2002 Consultores desde 1999 a 2002



¿Qué CASOS DE CONFLICTOS DE INTERESES se presentaron en WORLDCOM?







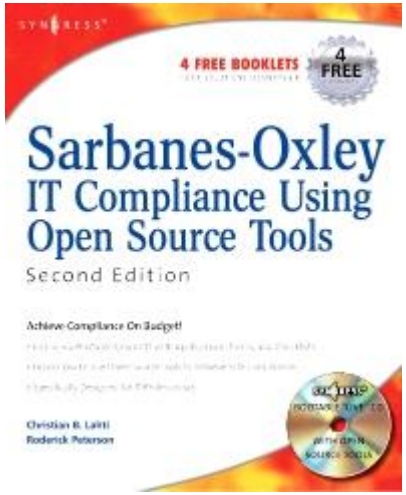
https://encoursa.com/blog/853o8121/waste-management-accounting-scandal

Waste Management – Fraude Contable

La Comisión de Bolsa y Valores (SEC) presentó una demanda contra Waste Management el 26 de marzo de 2002. Alegaron que la empresa infló sus ganancias en 1.700 millones de dólares, mientras que los altos ejecutivos ganaron millones de dólares y defraudaron a los inversores por 6.000 millones de dólares.

Thomas C. Newkirk, director asociado de la División de Cumplimiento Normativo de la SEC, declaró en el comunicado de prensa de la SEC que el fraude de Waste Management fue "uno de los fraudes contables más flagrantes que jamás hayamos visto. Durante años, estos acusados manipularon las cuentas, se enriquecieron, conservaron sus puestos de trabajo y engañaron a accionistas desprevenidos. La conducta fraudulenta de los acusados estuvo motivada por la codicia y el deseo de mantener sus cargos corporativos y su estatus en los ámbitos empresarial y social. Nuestro objetivo es eliminar el lucro del fraude de valores e impedir que los estafadores ocupen cargos directivos en empresas públicas".

Ley SARBANES-OXLEY (SOX) - 2002



Tras el Fraude de **ENRON** y **WORLDCOM, WASTE MANAGEMENT** y otras compañías, y que sacudieron la confianza del público, El Congreso de los Estados Unidos empezó una serie de aplicaciones para frenar la ola de fraudes millonarios de las empresas norteamericanas. Por ello se aprobó en 2002 una Ley de Reforma de Contabilidad de Compañías Públicas y protección al Inversionista, que entró en vigencia en Julio de 2002.

Sarbanes-Oxley Act Section 404

- PCAOB: Auditing Standard No. 2
  - Paragraph 24
    - Controls related to the prevention and detection of fraud often have a pervasive effect on the risk of fraud
    - Such controls include the adequacy of the internal audit activity and whether the internal audit function reports directly to the audit committee, as well as the extent of the audit committee's involvement and interaction with internal audit



AUDITING STANDARDS - AS del PCAOB
(Junta de Supervisión de Compañías Públicas Contables)

PCAOB
Public Company Accounting Oversight Board



(PCAOB) es una corporación privada sin fines de lucro creada por la **Ley Sarbanes-Oxley de 2002** para supervisar a las firmas que auditen a las empresas públicas (coticen en el Bolsa de New York o Nasdaq) con el fin de proteger los intereses de los inversionistas

COSO: Committee of Sponsoring Organizations of the Treadway Commission

COSO

COMMITTEE OF SPONSORING ORGANIZATIONS OF THE TREADWAY COMMISSION

SPONSORING ORGANIZATIONS:

- American Accounting Association — Thought Leaders in Accounting
- AICPA — American Institute of Certified Public Accountants
- fei — Financial Executives International
- ima — The Association of Accountants and Financial Professionals in Business
- The Institute of Internal Auditors



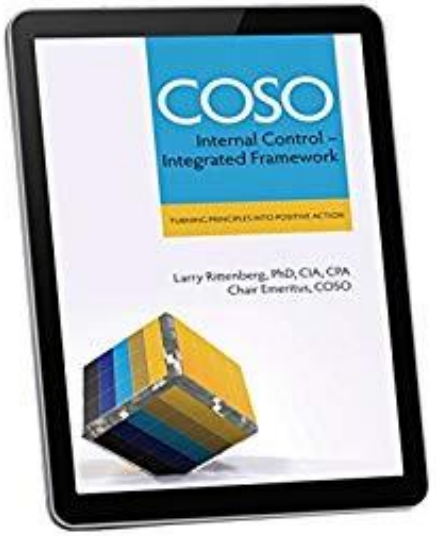
COSO I

ANTECEDENTES

- **1988** Se crea la Comisión TREADWAY es la que va a dar vida al Sistema COSO
- **1992** COSO publicó el MARCO INTEGRAL DE CONTROL INTERNO

OBJETIVOS

- Establecer una definición común de CONTROL INTERNO que responda a las necesidades de las distintas partes
- Mejorar la calidad de la información financiera
- Facilitar un modelo en base al cual las empresas y otras entidades puedan evaluar sus sistemas de CONTROL
- Definir un nuevo marco conceptual del control interno



INTERNAL CONTROL – INTEGRATED FRAMEWORK

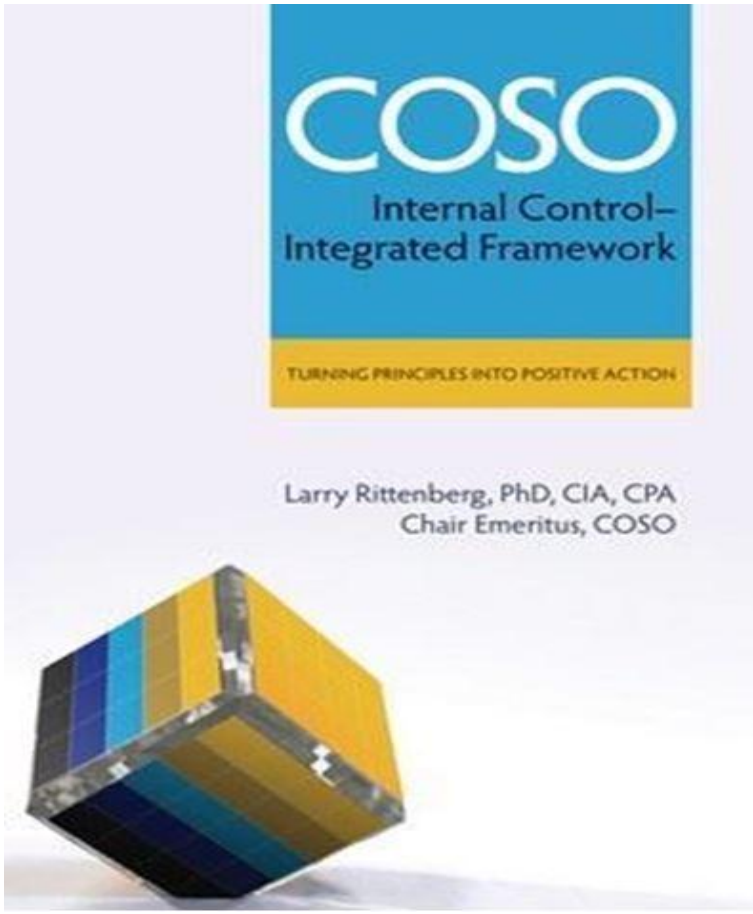
- ► Executive Summary
- ► Framework
- ► Reporting to External Parties
  September 1992
- ► Addendum to "Reporting to External Parties"
  May 1994

Committee of Sponsoring Organizations of the Treadway Commission

Control Interno – según COSO

Un proceso efectuado por el Directorio, la Gerencia y el personal en general, diseñado para proveer certeza razonable que se están alcanzando los objetivos estratégicos en lo referente a:

- Eficiencia y eficacia de las operaciones
- Confiabilidad de los reportes financieros
- Cumplimiento de las leyes y regulaciones vigentes.



COSO I

Cubo COSO



DEFINICION DE RIESGO

El Riesgo es la exposición a una situación donde hay una posibilidad de sufrir un daño o estar en peligro







RIESGO EMPRESARIAL





EL RIESGO Y EL SECTOR ASEGURADOR

Uno de los campos donde más se había utilizado y desarrollado el concepto riesgo era en el de **SEGUROS**.

El manejo del riesgo a través de un asegurador se inició en el transporte marítimo.

Este tipo de contratos, aunque costosos, constituyeron el inicio del mercado de seguros, y después paso a otros campos, como el seguro de vida.

El desarrollo industrial trajo consigo un incremento de los riesgos en las empresas, debido a los grandes cambios y a la diversidad de materiales, productos, herramientas, procesos, con el cual el sector asegurador creció.





EL RIESGO Y LOS INSTRUMENTOS FINANCIEROS

En las últimas décadas se han desarrollado INSTRUMENTOS FINANCIEROS, entre los que destacan los Derivados Financieros, tales como: OPCIONES, FUTUROS Y SWAPS, diseñados para proteger las inversiones ante las fluctuaciones de los PRECIOS, LAS TASAS DE CAMBIO, TASAS DE INTERES, COMMODITIES, etc, y que requieren en muchos de casos, medir el riesgo de los INSTRUMENTOS FINANCIEROS, utilizando una serie de probabilidades.







RIESGOS GENERADOS EN LA EMPRESA

Las Empresa al ejecutar sus procesos en busca del cumplimiento de sus objetivos, pueden exponerse a un sin numero de RIESGOS ESPECIFICOS e INDIVIDUALES: estos riesgos son llamados:

- **Riesgos Inherentes**
- **Riesgo de Reputación**
- **Riesgo de mercado y de Precios**
- **Incrementos en tasas de interés**
- **El Riesgo de liquidez y de Crédito**
- **Riesgos PAÌS**





El Modelo para la Identificación, Análisis, Tratamiento y Gestión de Riesgos

Estándares *Australiano Neozelandés:* AS-NZS 4360-2004 / AS NZ 4360:1999 / AS-NZS HB 436-2013



El Modelo recomendado para la Identificación, Análisis, Tratamiento y Gestión de Riesgos es el basado en los estándares *Australiano Neozelandés:* AS-NZS HB 436-2013 / ISO 31000-2009 y 2018 / AS-NZS 4360-2004 / AS NZ 4360:1999

Además se considera para la base de fundamento, los Modelos vigentes de GESTION DE RIESGO EMPRESARIAL (ERM) emitidos por el Comité COSO de la Comisión Treadway.

- COSO II ERM 2004: “Gestión de Riesgo Empresarial”
- COSO III: “Gestión de Riesgo Empresarial, Alineación del Riesgo con la Estrategia y el Desempeño” – 2017



AS/NZS 4360:1999
Estándar Australiano
Administración de Riesgos

Administración de Riesgos

Alcance

Este Estándar provee una guía genérica para el establecimiento e implementación el proceso de administración de riesgos involucrando el establecimiento del contexto y la identificación, análisis, evaluación, tratamiento, comunicación y el monitoreo en curso de los riesgos.

Aplicación

La administración de riesgos es reconocida como una parte integral de las buenas prácticas gerenciales. Es un proceso iterativo que consta de pasos, los cuales, cuando son ejecutados en secuencia, posibilitan una mejora continua en el proceso de toma de decisiones.
Administración de riesgos es el término aplicado a un método lógico y sistemático de establecer el contexto, identificar, analizar, evaluar, tratar, monitorear y comunicar los riesgos asociados con una actividad, función o proceso de una forma que permita a las organizaciones minimizar pérdidas y maximizar oportunidades. Administración de riesgos es tanto identificar oportunidades como evitar o mitigar pérdidas.
Este Estándar puede ser aplicado a todas las etapas de la vida de una actividad, función, proyecto, producto o activo. El beneficio máximo se obtiene generalmente aplicando el proceso de administración de riesgos desde el principio.

Administración de Riesgos

Requerimientos de administración de riesgos

Propósito

El propósito de esta Sección es describir un proceso formal para establecer un programa sistemático de administración de riesgos.

Se necesita el desarrollo de una política organizacional de administración de riesgos y un mecanismo de soporte con objeto de proveer una estructura para llevar a cabo un programa de administración de riesgos más detallado a nivel sub-organizacional o de proyecto.

Política de administración de riesgos

El ejecutivo de la organización debe definir y documentar su política para administración de riesgos, incluyendo objetivos para, y su compromiso con, la administración de riesgos. La política de administración de riesgos debe ser relevante para el contexto estratégico de la organización y para sus metas, objetivos y la naturaleza de su negocio. La gerencia asegurará que esta política es comprendida, implementada y mantenida en todos los niveles de la organización.

Administración de Riesgos

Planeamiento y recursos

Compromiso gerencial

La organización debería asegurar que:

a) se ha establecido, implementado y mantenido un sistema de administración de riesgos, de acuerdo con este Estándar; y
b) se reporta el desempeño del sistema de administración de riesgos a la gerencia de la organización para revisión y como base para su mejora.

Responsabilidad y autoridad

Deberá definirse y documentarse la responsabilidad, autoridad e interrelaciones del personal que realiza y verifica el trabajo que afecta la administración de riesgos, particularmente para la gente que necesita la libertad y autoridad organizacional para realizar una o más de las siguientes acciones:

a) iniciar acciones para prevenir o reducir los efectos adversos de los riesgos;
b) controlar el tratamiento posterior de los riesgos hasta que el nivel de riesgo se haga aceptable;
c) identificar y registrar cualquier problema relativo a la administración de riesgos;
d) iniciar, recomendar o proveer soluciones a través de los canales asignados;
e) verificar la implementación de soluciones; y
f) comunicar y consultar interna y externamente según corresponda.

Administración de Riesgos

Recursos

La organización debe identificar los requerimientos de recursos y proveer recursos adecuados, incluyendo la asignación de personal entrenado para las actividades de administración, desempeño del trabajo, y verificación incluyendo la revisión interna.

Programa de implementación

Se requiere seguir una cantidad de pasos para implementar un sistema efectivo de administración de riesgos dentro de una organización. En el Apéndice B se proveen ejemplos. Dependiendo de la filosofía, cultura y estructura general de administración de riesgos de la organización, debería ser posible combinar u omitir ciertos pasos. Sin embargo, deberían considerarse todos los pasos.

Revisión gerencial

El ejecutivo de la organización debe asegurar que se lleve a cabo una revisión del sistema de administración de riesgos a intervalos especificados, suficiente para asegurar su continua conformidad y efectividad para satisfacer los requerimientos de este Estándar, y las políticas y objetivos de administración de riesgos establecidos en la organización

esan GRADUATE SCHOOL OF BUSINESS

International Organization for Standardization

ISO

31000

Risk-Management



INTERNATIONAL CERTIFICATIONS

ISO 31000:2009

ISO 31000:2018 published

ISO TC 262



ISO 31000:2009

ISO 31000:2018 published

ISO TC 262

NO ESPERAMOS TENER ACCIDENTES



ISO 31000:2018 published

ISO TC 262

Pero A VECES LOS EVENTOS NEGATIVOS OCURREN (Desastres)





ISO 31000:2018 published

ISO TC 262

- Riesgo crediticio
- Riesgo operacional
- Riesgo tecnológico
- Riesgo estratégico
- Riesgo legal
- Riesgo de mercado
- Riesgo de liquidez
- Riesgo de cumplimiento
- No satisfacer los requisitos del cliente
- Peligros Ambientales
- Riesgo de Seguridad Alimenticia (HACCP)
- Peligro para el ser humano
- Riesgo reputacional
- …



ISO 31000:2018
published
ISO TC 262

¿Por qué no Analizar Riesgos?

- No aporta valor…
- Si pensamos en todo lo malo, no hacemos nada
- Hay suficientes controles.
- Acá pensamos en metas, no en riesgos.
- Aceptamos que es común que fallen los Sistemas (TI)
- ! No hay tiempo para evaluar Riesgos, necesito vender !
- Acá nunca pasó nada.
- No tenemos los procesos definidos.
- Gestionar los riesgos no me va a ayudar a vender más.
- Si ocurre algo, ya lo arreglaremos.

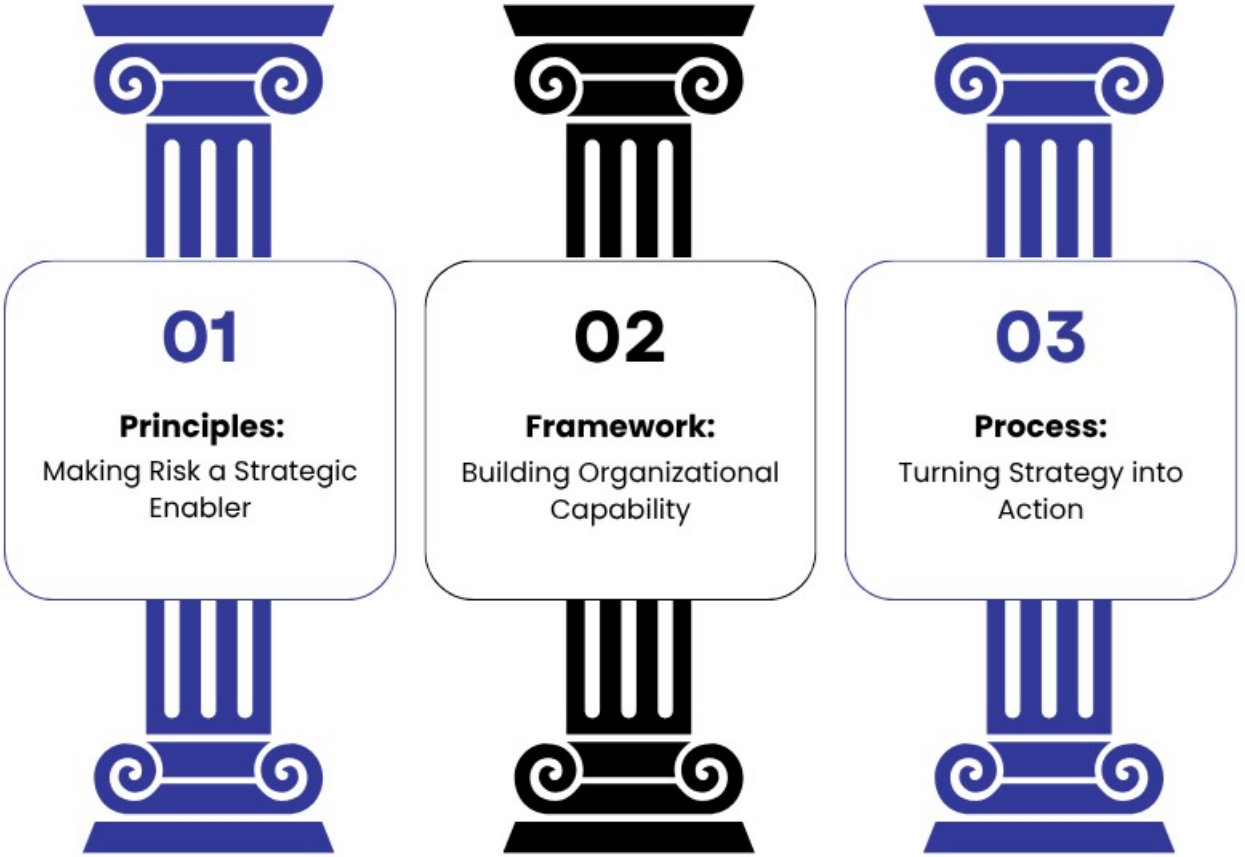
esan GRADUATE SCHOOL OF BUSINESS

ISO 31000:2009

ISO 31000:2018 published

ISO TC 262

The Three Pillars of ISO 31000



ISO 31000:2018 published

¿Qué es riesgo?

"Es el efecto de la incertidumbre en la consecución de los objetivos"

ISO 31000:2018

1. Incertidumbre (puede que nunca ocurra).

2. El riesgo importa y debe gestionarse porque tiene un efecto siempre negativo

3. Ese efecto es sobre los objetivos fijados.

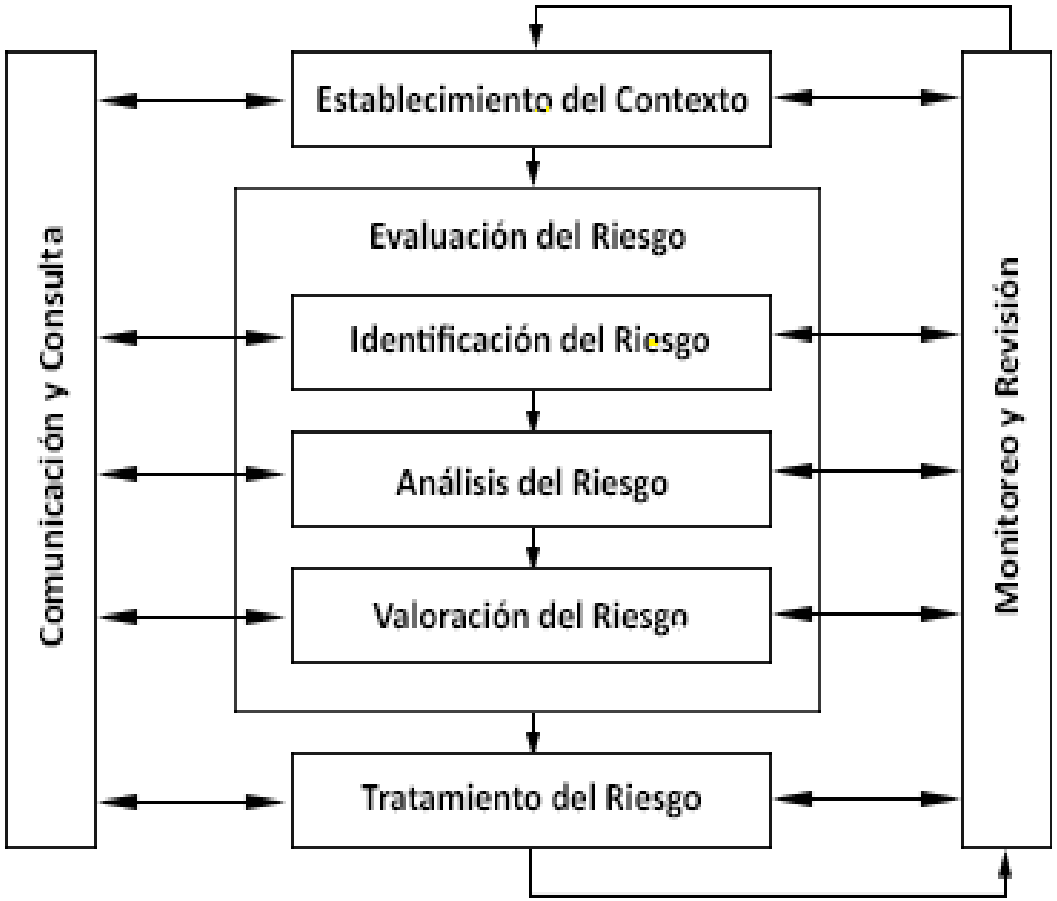
TERMINOLOGÍA DE ADMINISTRACIÓN DE RIESGOS
(SEGÚN EL ESTÁNDAR AUSTRALIANO NEOZELANDÉS)

- ✓ Aceptación de riesgo
- ✓ Actitud de Riesgo
- ✓ Actividades de Control
- ✓ Administración de Riesgos
- ✓ Amenaza
- ✓ Análisis de Riesgo
- ✓ Análisis cualitativo
- ✓ Análisis cuantitativo
- ✓ Análisis de sensibilidad
- ✓ Comunicación y Consulta
- ✓ Consecuencia (Impacto)
- ✓ Contexto externo
- ✓ Contexto interno
- ✓ Controlar
- ✓ Control de riesgo
- ✓ Costo de los controles
- ✓ Criterios de Riesgo
- ✓ Establecer el contexto
- ✓ Evaluación de Riesgos
- ✓ Evento
- ✓ Evitar un riesgo
- ✓ Financiamiento de riesgos
- ✓ Frecuencia

- ✓ Fuente de Riesgo
- ✓ Gestión de Riesgos
- ✓ Identificación de riesgos
- ✓ Juicio sobre controles
- ✓ Mapa de Riesgo
- ✓ Marco Gestión de Riesgos
- ✓ Monitoreo
- ✓ Nivel de Riesgo
- ✓ Pérdida
- ✓ Perfil de Riesgo
- ✓ Plan de acción
- ✓ Plan de Gestión de Riesgos
- ✓ Política Gestión de Riesgos
- ✓ Probabilidad
- ✓ Proceso Gestión de Riesgos
- ✓ Propietario de Riesgo
- ✓ Reducción de riesgos
- ✓ Retención de riesgos
- ✓ Riesgo
- ✓ Riesgo máximo aceptable
- ✓ Riesgo residual
- ✓ Supervisión
- ✓ Tomador de decisiones
- ✓ Transferir riesgos
- ✓ Tratamiento de riesgos
- ✓ Vulnerabilidad.

FASES PARA LA GESTIÓN DE RIESGOS

La Gestión de Riesgos visto como un proceso continuo y permanente dentro de las Empresas que han adoptado el Modelo de Control Interno ERM, incluye un conjunto de Fases que se describen a continuación. Algunas son secuenciales y otras implican el desarrollo de actividades en paralelo. Para cada Fase se detalla la entrada y salida del proceso y las actividades.



COSO II

El nuevo marco amplia la visión del riesgo a eventos negativos o positivos, o sea, las AMENAZAS Y OPORTUNIDADES; a la localización de un nivel de tolerancia al riesgo; así como al manejo de estos eventos mediante portafolios de riesgos.

ANTECEDENTES

2004 El proyecto culminó con la publicación, por parte del Committee del Enterprise Risk Management - Integrated Framework (COSO II) y sus Aplicaciones Técnicas asociadas.

Actualmente la mayoría de las organizaciones adoptan este nuevo enfoque que les permite mejorar sus prácticas de control interno con un enfoque de riesgos.



COSO II



GESTION DE RIESGOS

Es un proceso efectuado por el Directorio de una Compañía, las Gerencias Ejecutivas y el resto del personal diseñado para:

- Identificar eventos potenciales que puedan afectar los objetivos de una Empresa
- Gestionar sus riesgos dentro de lo aceptable; y
- Proporcionar una seguridad razonable sobre el logro de los objetivos

COSO II



VENTAJAS DE LA GESTIÓN DE RIESGOS

- Mejora las decisiones de respuesta al riesgo ya que proporciona información para identificarlos y permite seleccionar entre las posibles alternativas las respuestas a ellos.
- Permite al Directorio y a la Gerencia de la empresa, tener una visión global del riesgo y accionar los planes para su correcta gestión.
- Reduce las sorpresas y las pérdidas operativas ya que las entidades consiguen mejorar su capacidad para identificar los eventos potenciales.
- Identifica y gestiona la diversidad de riesgos en la empresa.

ESTRUCTURA DE CONTROL INTERNO
OCHO COMPONENTES

Cubo COSO II





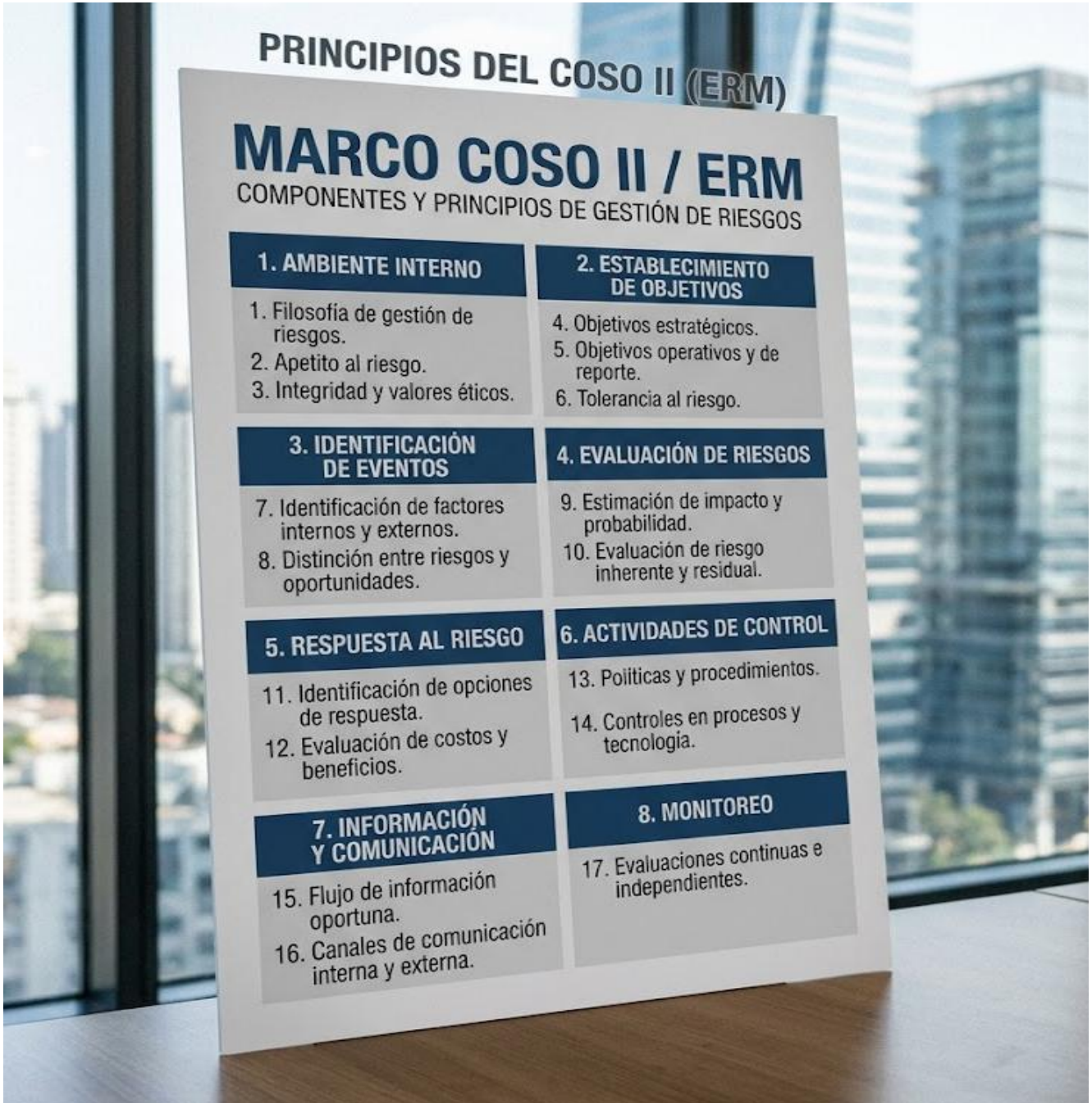
COSO II



Principios Fundamentales

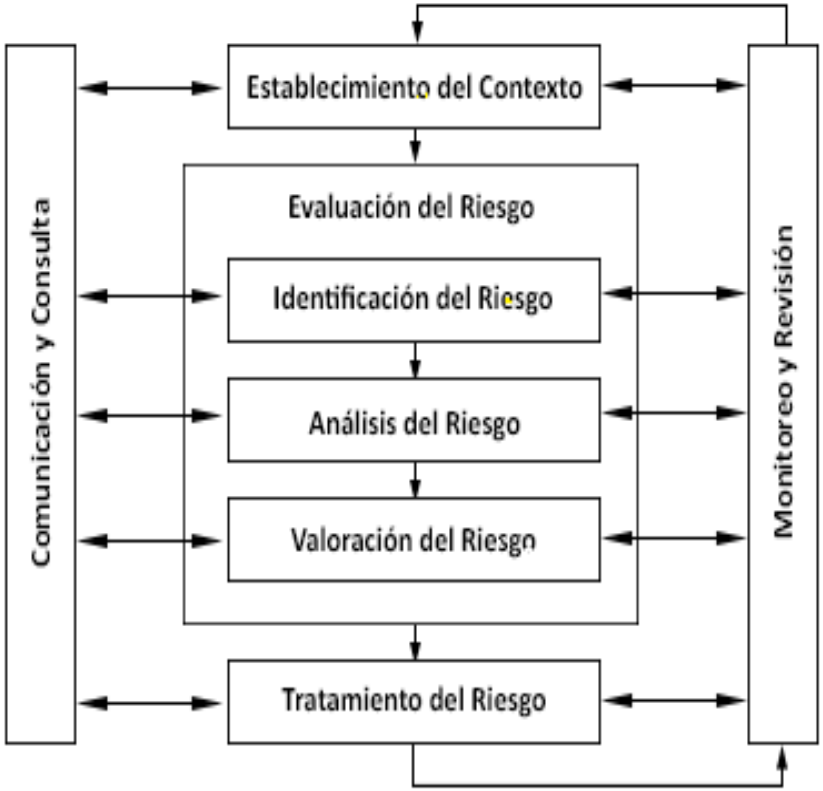


Los 17 principios fundamentales de COSO II 2004 (asociados a 5 Componentes de Control Interno)



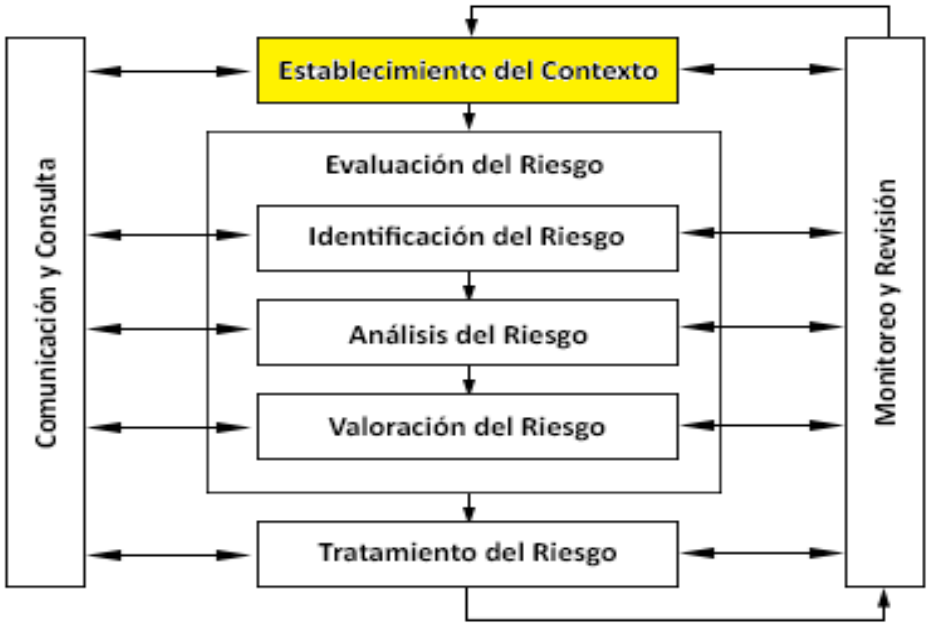


Fases para la GESTIÓN DE RIESGOS



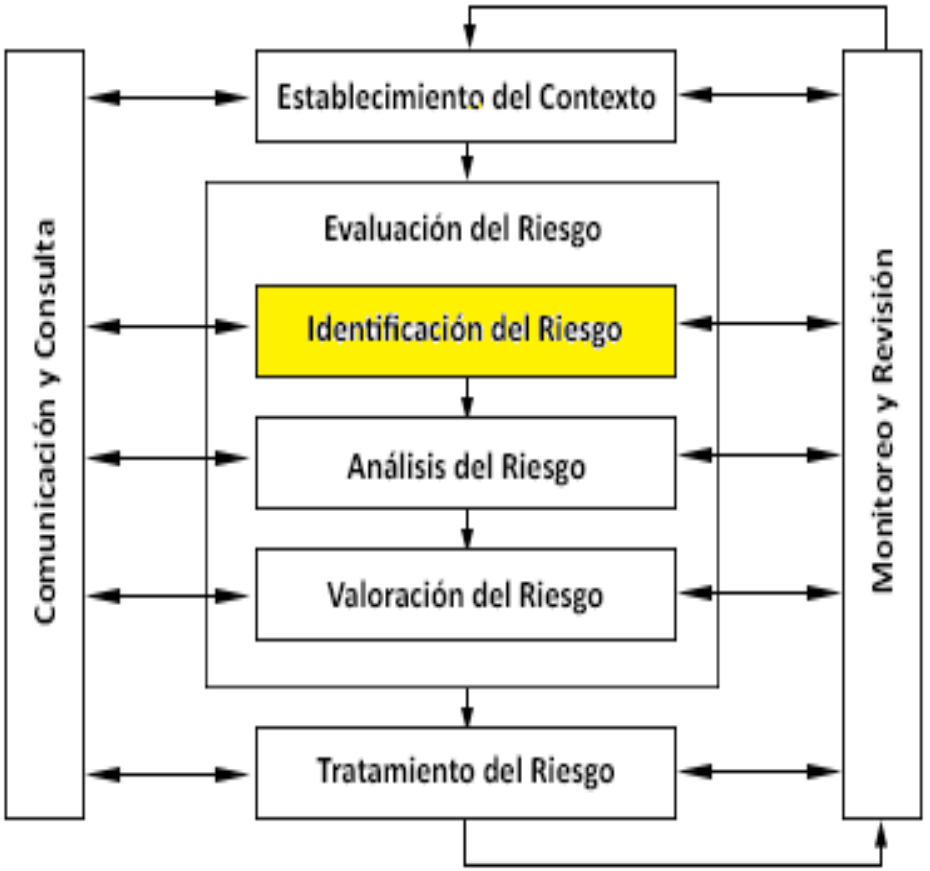
FASE I: ESTABLECER EL CONTEXTO

El proceso ocurre dentro de la estructura del contexto estratégico, organizacional y de administración de riesgos de una organización. Esto necesita ser establecido para definir los parámetros básicos dentro de los cuales deben administrarse los riesgos y para proveer una guía para las decisiones dentro de estudios de administración de riesgos más detallados



FASE II: IDENTIFICAR RIESGOS

La utilización de CHECK LIST, FODA, FLUJOGRAMAS, BRAINSTORMING, ANALISIS DE ESCENARIOS, MAPA DE PROCESOS entre otros, nos permitirá identificar posibles situaciones de riesgo, ya que mediante su llenado o desarrollo nos ayudará también a identificar anomalías o carencias preventivas en el área bajo análisis.



Metodología para la identificación y evaluación Cualitativa de Riesgos

Los responsables de procesos y subprocesos tienen la obligación de efectuar la identificación y evaluación de los riesgos, y si tendrían efecto negativo.

Deberán elaborar la **Planilla de Identificación de Riesgos** del o los Subprocesos asignados para revisión.

Project Name:	Concierto
Project No:	005
Project Manager	C. Turley
Project Exective:	G. Johnson

Riesgo	
ALTO	> €4,000
MEDIO	> €1,500
BAJO	< €1,500

Registro de Riesgos													
ID	Autor del riesgo	Fecha de registro	Categoria del riesgo	Descripción del riesgo	Probabilidad% x Impacto			Proximidad	Categoria de la Respuesta	Respuesta al riesgo	Estado	Propietario	Ejecutor
56	G. Patrick	20/10	Seguridad	Por razones de seguridad la autorización peligra	4	€30.000	€1.200	Medio plazo	Reduce	Work with city officer, create plan	Active	K.Jones	W. Maths
57	P. Smith	21/10	Organización	Debido al verano, hay riesgo de no encontrar suficientes camareros	66	€6.100	€4.026	Largo plazo	Reduce	Try to work with volenteers	Active	T. Jarvis	T. Jarvis
58	K. Jackson	25/10	Financiero	El tiempo en Reino Unido tiempo, la lluvia reducirá el consumo de cerveza	15	€3.500	€2.500	Largo plazo	Reduce	Look at other drinks to sell	Active	Y. Young	O. Stella


INVENTARIO DE RIESGOS

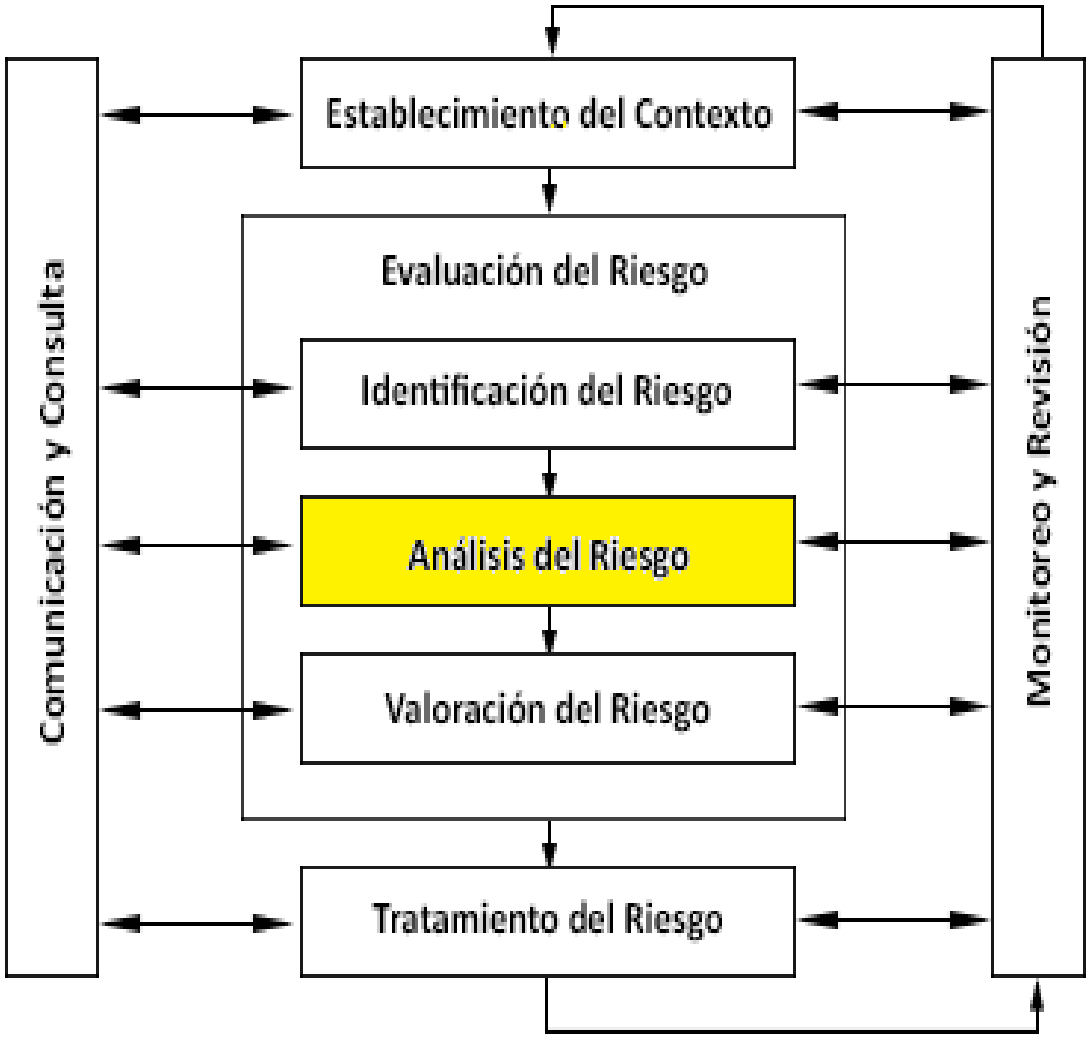
FASE III: ANALIZAR RIESGOS

Esta fase comprende lo siguiente:

1) Analizar las amenazas identificadas en términos de **PROBABILIDADES e IMPACTOS.**

.

2) Identificar y valuar los **CONTROLES IMPLEMENTADOS** para Mitigar dichos Riesgos



Criterios Cualitativos para determinar la PROBABILIDAD de los Riesgos

Escala de PROBABILIDAD

Nivel	Probabilidad de ocurrencia del evento	Descripción
5	Casi certeza	Hay una casi certeza de que este evento ocurrirá y las condiciones son altamente propicias para ocasionar su materialización. Existe una gran probabilidad de que dicho evento ocurra mas de doce veces al año
4	Muy frecuente	Puede ocurrir por lo menos dos veces al año.
3	Frecuente	Puede ocurrir por lo menos una vez al año. Las condiciones son medianamente favorables para permitir su ocurrencia
2	Ocasional	Puede ocurrir por lo menos una vez cada dos años o mas.
1	Rara vez	Puede ocurrir por lo menos una vez cada diez años o mas. No existen condiciones que permitan su ocurrencia

Criterios Cualitativos para determinar la PROBABILIDAD de los Riesgos

Escala de IMPACTO

Nivel	IMPACTO
5	Catastrófico
4	Alto
3	Moderado
2	Menor
1	Insignificante

Escala de CONTROLES implementados

Puntaje	Evaluación de los controles	Descripción
4	Adecuados	Los controles se aplican en forma consistente y la evidencia de su aplicación se encuentra debidamente documentada. Se estima que no requiere agregarse nuevos controles.
2	A mejorar	Si bien existen controles, no son suficientes para mitigar la amenaza. Pueden fortalecerse e incluirse nuevos controles. La evidencia de su aplicación es baja.
1	A implementar	No existen controles para la amenaza evaluada.

Índice de Exposición al Riesgo

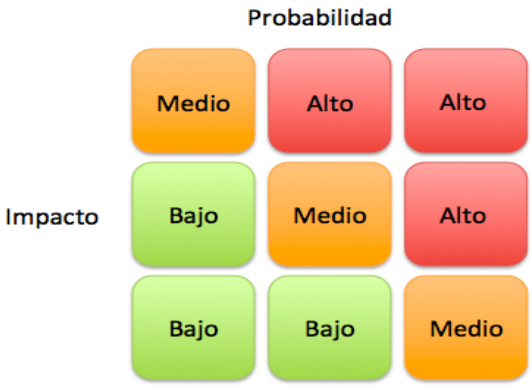
A efectos de poder categorizar los riesgos por su criticidad, se define lo siguiente:

- Índice de Exposición al Riesgo= $\frac{\text{Probabilidad X Impacto}}{\text{Juicio sobre A. Control}}$

- En la medida que a los diversos juicios emitidos se les asocia un puntaje a través de una planilla excel, es posible calcular dicho índice.
- Según las escalas definidas la probabilidad de ocurrencia varia de 1 (Rara vez) a 5 (Casi certeza), el Impacto también de 1 (Insignificante) a 5 (Catastrófico).
- Las escalas de los controles varia de 1 (A Implementar) a 4 (Adecuado).

Cantidad de Niveles de Juicio

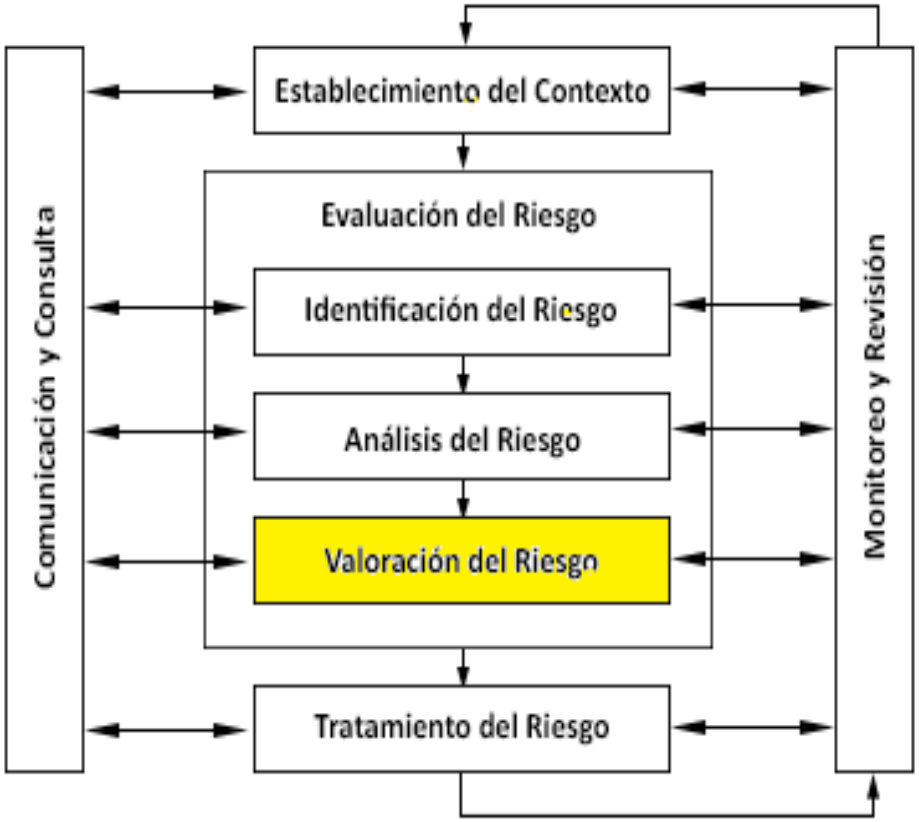
PROBABILIDAD							
	CASI CERTEZA	5	5	10	15	20	25
	FRECUENTE	4	4	8	12	16	20
	MUY FRECUENTE	3	3	6	9	12	15
	OCASIONAL	2	2	4	6	8	10
	RARA VEZ	1	1	2	3	4	5
			1	2	3	4	5
			INSIGNIFICANTE	MENOR	MODERADO	ALTA	CATASTROFICO
		IMPACTO					



PROBABILIDAD					
	ALTA	3	3	6	9
	MEDIA	2	2	4	6
	BAJA	1	1	2	3
			1	2	3
			BAJA	MEDIA	ALTA
		IMPACTO			

FASE IV: EVALUAR RIESGOS

Consiste en comparar el nivel de riesgo detectado durante el proceso de análisis contra el nivel de Riesgo Máximo Aceptable que define el DIRECTORIO.
Esto posibilita que los riesgos sean ordenados como para identificar las prioridades de acciones para mitigar los riesgos.



Mapa de Riesgos

El mapa de riesgos se emplea también como una herramienta para representar gráficamente la **probabilidad de ocurrencia y el impacto** para cada uno de los riesgos identificados y a los que se encuentra expuesta la empresa.

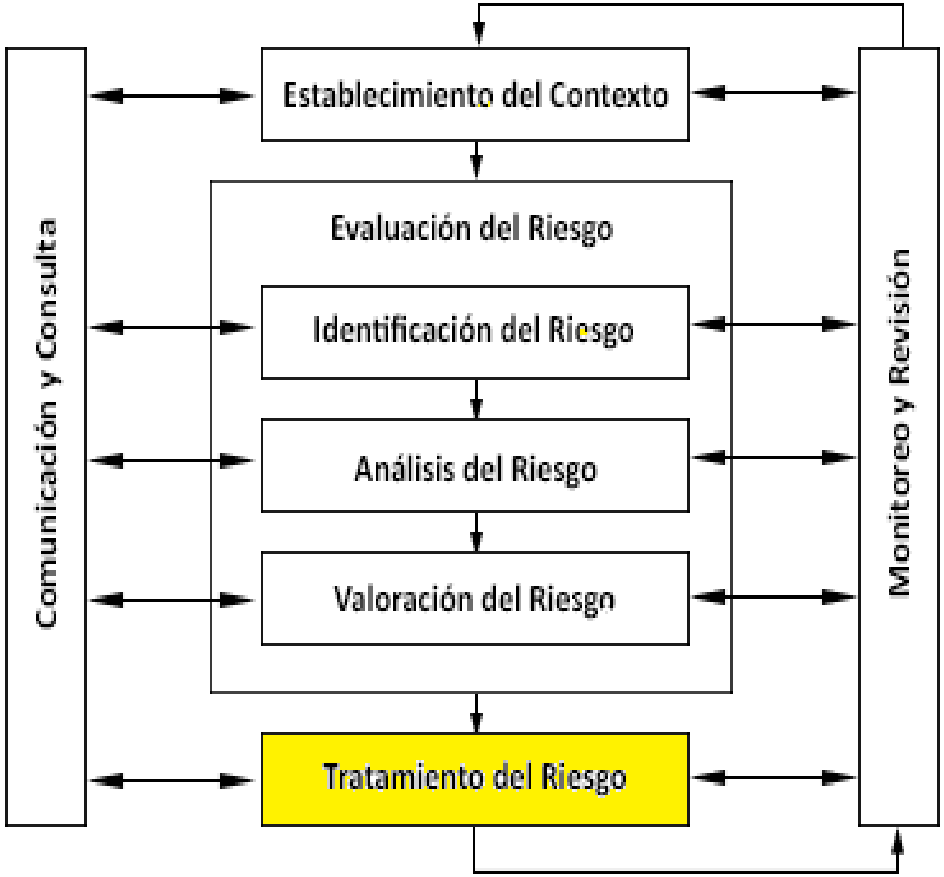
Riesgo Máximo Aceptable

La Empresa a través del DIRECTORIO definirá cuales riesgos son inaceptables. Estos niveles se determinaran en forma previa a la evaluación del riesgo y podrán ser revisados anualmente por Auditoria.



FASE V: TRATAR RIESGOS

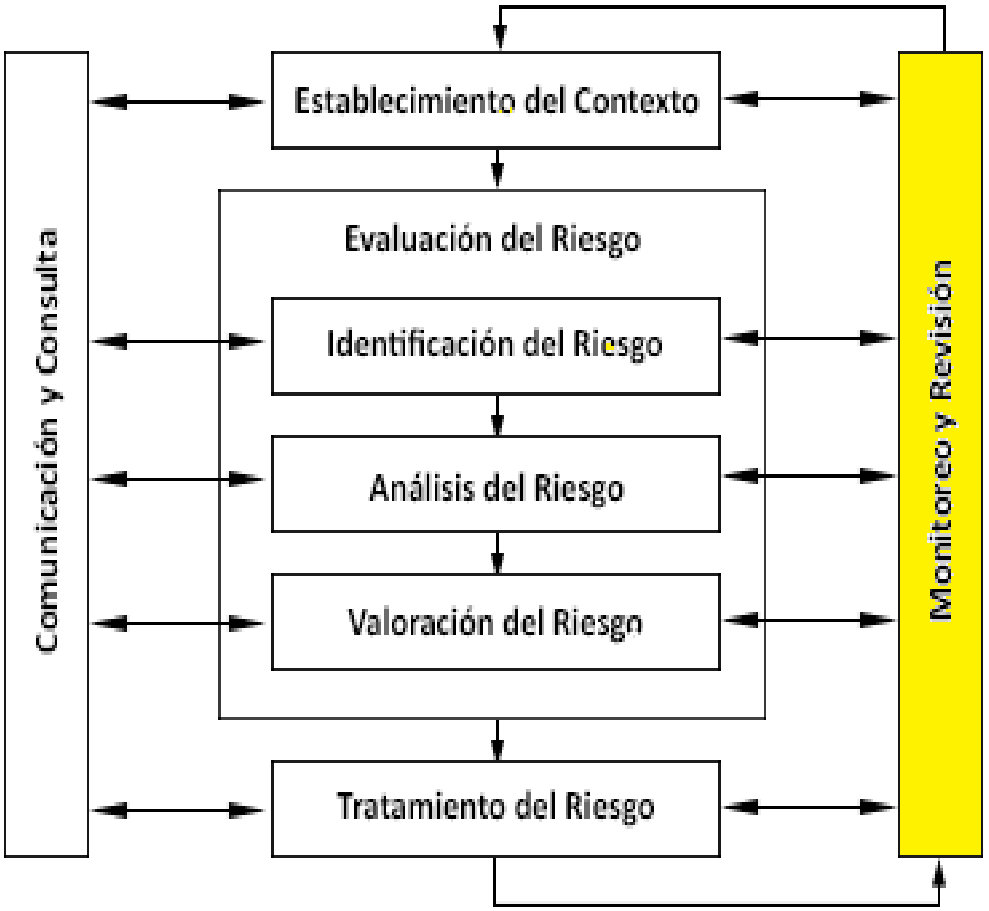




FASE VI: MONITOREAR Y REVISAR

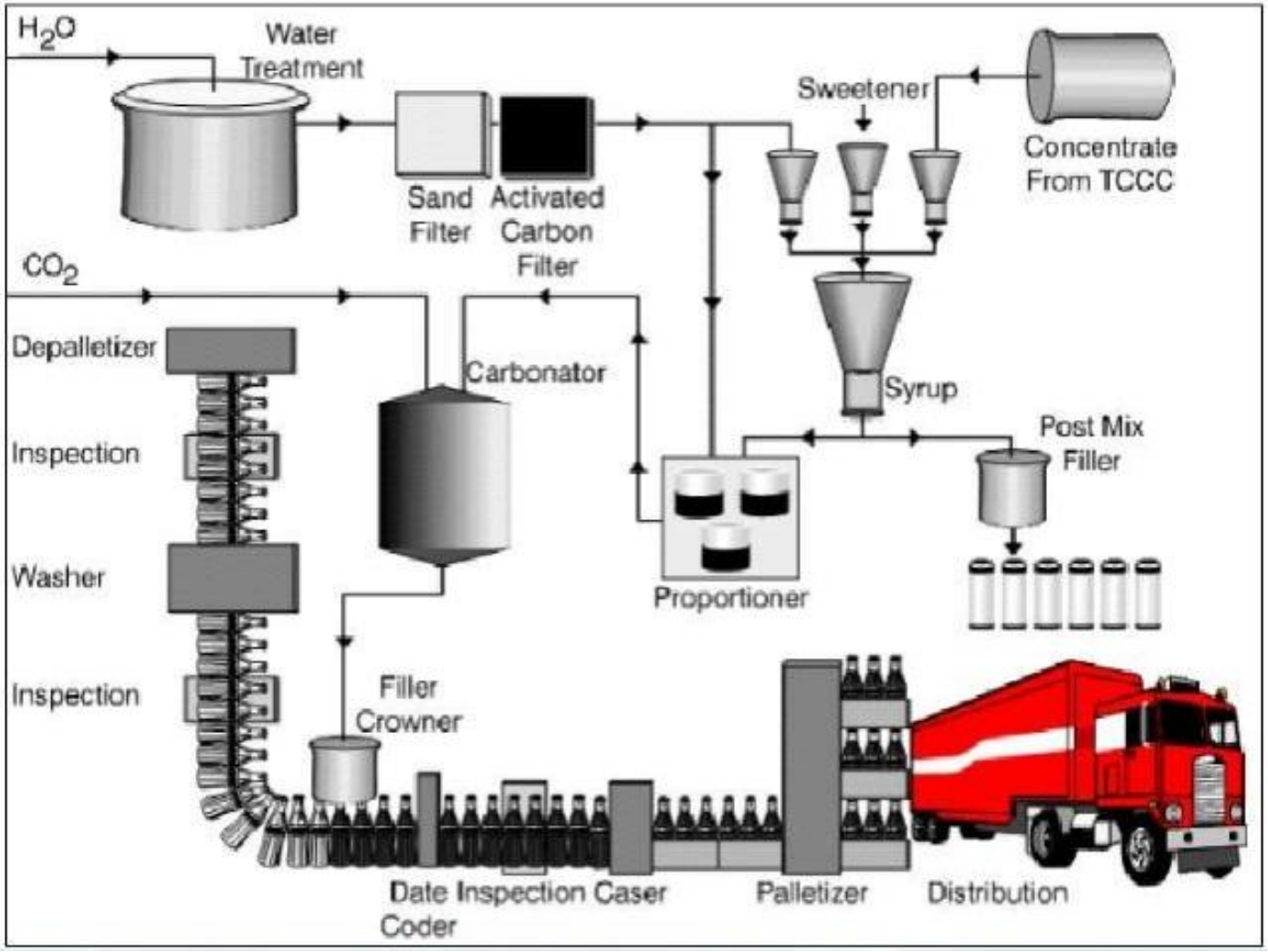
Consiste en Monitorear y revisar el desempeño del sistema de Administración de Riesgos y los cambios que podrían afectarlo.

También forman parte del monitoreo las acciones periódicas que se efectúen para identificar amenazas no previstas originalmente.



Revisión de Procesos:

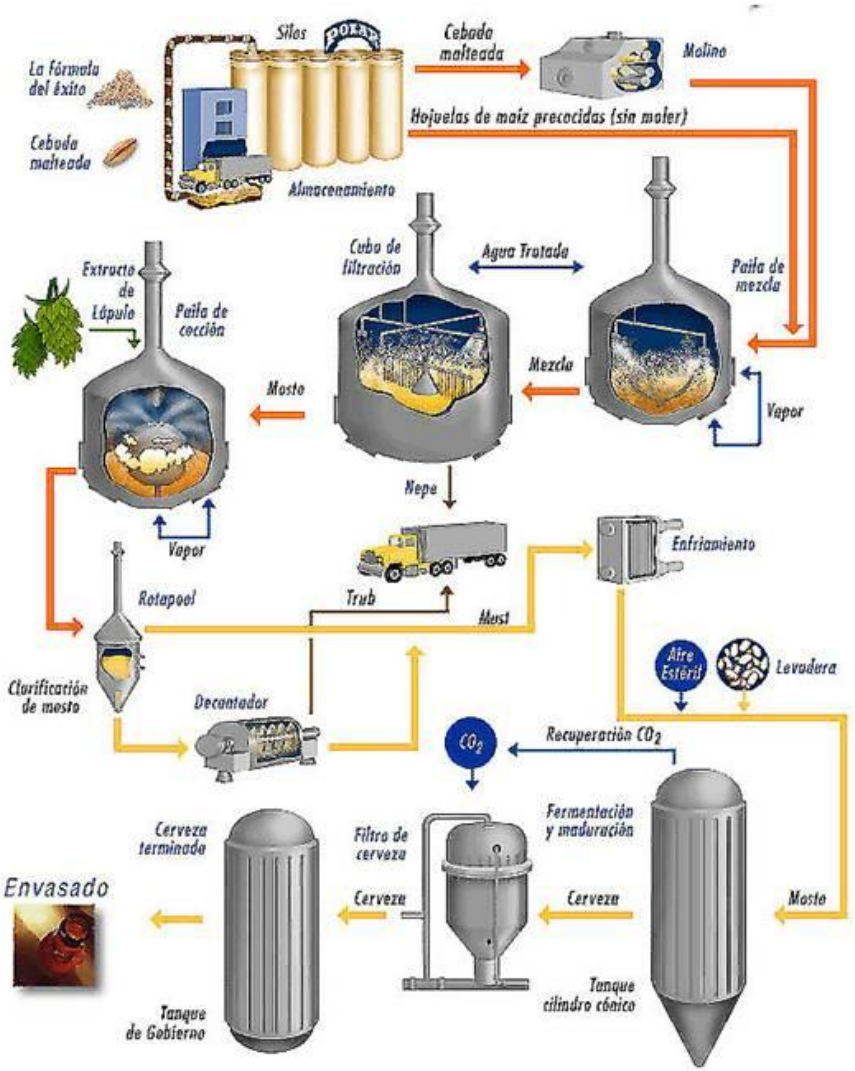






Revisión de los Procesos:





Caso SOBRE CONTROLES



A finales de los 90s, en una de las salas de los multicines *Cine Planet,* el Cajero ubicado en una isla a la entrada del cine, como parte de sus tareas rutinarias, recibía el efectivo de los clientes y manejaba una máquina que arrojaba tickets pre numerados.

Al entrar a la sala, los clientes entregaban el ticket al empleado que estaba en la puerta de la sala (a 10 metros aproximadamente de la cabina del cajero).

El empleado rompía el ticket por la mitad, abría la puerta para que entre el cliente y le devolvía la otra mitad. La primera mitad del ticket era arrojada por el empleado a un buzón.

- ¿Qué controles existían sobre el manejo de recepción del efectivo?
- ¿Qué pasos debía dar regularmente el Supervisor para dar máxima efectividad a estos controles?
- Suponga que el cajero y el de la puerta decidían ponerse de acuerdo para sustraer efectivo: ¿Qué acciones podrían tomar?
- A partir del supuesto anterior "de colusión" entre el cajero y el empleado en la puerta. ¿Qué tipos de controles permitirían probablemente revelar el desfalco?
- **Actualmente, como han sido superadas estas debilidades de Control, en este tipo de negocio**

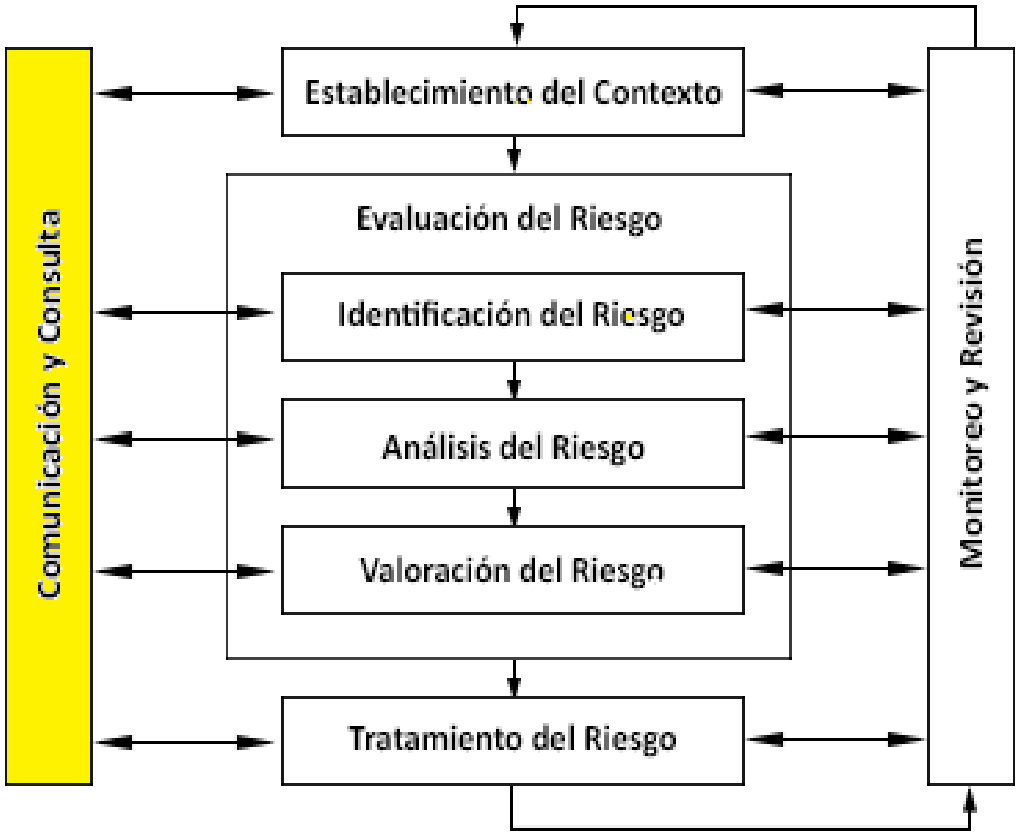

CINEMARK



FASE VII: COMUNICAR Y CONSULTAR

Comunicar y consultar con interesados internos y externos según corresponda en cada etapa del proceso de administración de riesgos.

El DIRECTORIO debe estar informado de los avances del proceso de Gestión de Riesgos. Cada responsable de procesos y subprocesos así como sus supervisores siguiendo la escala jerárquica, asumen la responsabilidad de mantener los riesgos dentro de los niveles aceptables, para lo cual debe recibir la información específica sobre los riesgos que gestiona.



COSO III

COSO COMMITTEE OF SPONSORING ORGANIZATIONS OF THE TREADWAY COMMISSION

Gestión de Riesgo Empresarial
(Enterprise Risk Management – ERM) 2017

Alineación del Riesgo con la Estrategia y el Desempeño

The Committee of Sponsoring Organizations of the Treadway Commission (COSO)

RESUMEN EJECUTIVO



(Traducción: Mario Vergara Silva)

SPONSORING ORGANIZATIONS:

American Accounting Association – Thought Leaders in Accounting
AICPA – American Institute of Certified Public Accountants
fei – financial executives international
ima – The Association of Accountants and Financial Professionals in Business
The Institute of Internal Auditors

COSO III





La ampliación del año 2017 permitió corregir aspectos del marco original, no limitándose a la fiabilidad de la información financiera sino que debía abarcar además a todo tipo de información. Se consideró oportuno señalar que los objetivos fueran operativos, de Reporting o de cumplimiento operativo.

COSO III



OBJETIVOS

- Ampliar su aplicación al expandir los objetivos operativos y de emisión de informes.
- Permitir una MAYOR COBERTURA de los RIESGOS a los que se enfrentan actualmente las organizaciones.
- Actualizar el contexto de la aplicación del control interno a muchos cambios en las empresas y ambientes operativos
- Aclarar los requerimientos del control interno.

COSO III



CINCO NUEVOS COMPONENTES

1. GOBIERNO Y CULTURA
2. ESTRATEGIA Y ESTABLECIMIENTO DE OBJETIVOS
3. ACTUACIÓN
4. REVISAR Y REVISIÓN (Auditores)
5. INFORMACIÓN, COMUNICACIÓN Y PRESENTACIÓN DE INFORMES

COSO III

Los 20 Principios que comprenden son:

1) Ejerce la Supervisión de Riesgos de la Junta
2) Establece estructuras operativas
3) Define la Cultura deseada
4) Demuestra compromiso con los valores fundamentales
5) Atrae, desarrolla y retiene individuos capaces
6) Analiza el Contexto Empresarial
7) Define el Apetito de Riesgo
8) Evalúa estrategias alternativas
9) Formula objetivos del negocio
10) Identifica el Riesgo
11) Evalúa la gravedad del Riesgo
12) Prioriza los Riesgos
13) Implementa Respuestas al Riesgo
14) Desarrolla vista de portafolio de Riesgo
15) Evalúa cambios sustanciales
16) Revisa el Riesgo y el Desempeño
17) Persigue la mejora en la Gestión de Riesgos Empresariales
18) Aprovecha la información y la tecnología
19) Comunica información de Riesgo
20) Informes sobre Riesgo, Cultura y Desempeño



DIFERENCIAS entre COSO I, II y III



Diferencias	COSO I	COSO II	COSO III
Titulo			
Objetivos	✓ Eficacia y eficiencia de las operaciones ✓ Confiabilidad de la información financiera ✓ Cumplimiento de las leyes, reglamentos y normas que sean aplicables	✓ Mejora las decisiones de respuesta al riesgo. ✓ Permite a la dirección de la empresa tener una visión global del riesgo. ✓ Identifica y gestiona la diversidad de riesgos en la empresa	✓ Mejora de la agilidad de los sistemas de gestión de riesgos para adaptarse a los entornos ✓ Mayor confianza en la eliminación de riesgos y consecución de objetivos ✓ Mayor claridad en cuanto a la información y comunicación.
Componentes	**Tiene 5 Componentes:** 1. Ambiente de Control 2. Evaluación de Riesgos 3. Actividades de Control 4. Información y Comunicación 5. Supervisión	**Tiene 8 Componentes:** 1. Ambiente Interno **2. Establecimiento de Objetivos** **3. Identificación de Eventos** **4. Evaluación de Riesgos** **5. Respuesta a los Riesgos** 6. Actividades de Control 7. Información y Comunicación 8. Supervisión o Monitoreo	**Tiene 5 Componentes:** 1.GOBIERNO Y CULTURA 2.ESTRATEGIA Y ESTABLECIMIENTO DE OBJETIVOS 3.ACTUACIÓN 4.REVISAR Y REVISIÓN (Auditores) 5.INFORMACIÓN, COMUNICACIÓN Y PRESENTACIÓN DE INFORMES
PRINCIPIOS		**Tiene 17 Principios**	**Tiene 20 principios (antes 23)**



COSO ERM 2004

Es la sigla de COSO Enterprise Risk Management y data del año 2004. Nació como complemento de COSO I que se publicó el año 1992 y que era fundamentalmente para control interno. COSO se actualizó y sistematizó el año 2013 con 17 principios.

COSO ERM tiene su foco en riesgos e incluye las estrategias, lo que COSO no considera.

COSO ERM 2017

Entre 2004 y 2016 los negocios cambiaron y se hicieron más complejos incluyendo los riesgos, lo que llevó a la revisión y actualización del framework 2004 llevando a COSO ERM propuesto 2016.

COSO ERM 2017 tiene lo siguiente que no tiene COSO ERM 2016:

- COSO ERM 2017 incluye las estrategias.
- COSO ERM 2017 incluye establecimientos de objetivos, la identificación de eventos y la respuesta a los riesgos.

COSO ERM 2017



PRINCIPALES CAMBIOS DE COSO ERM 2017 CON COSO ERM 2004

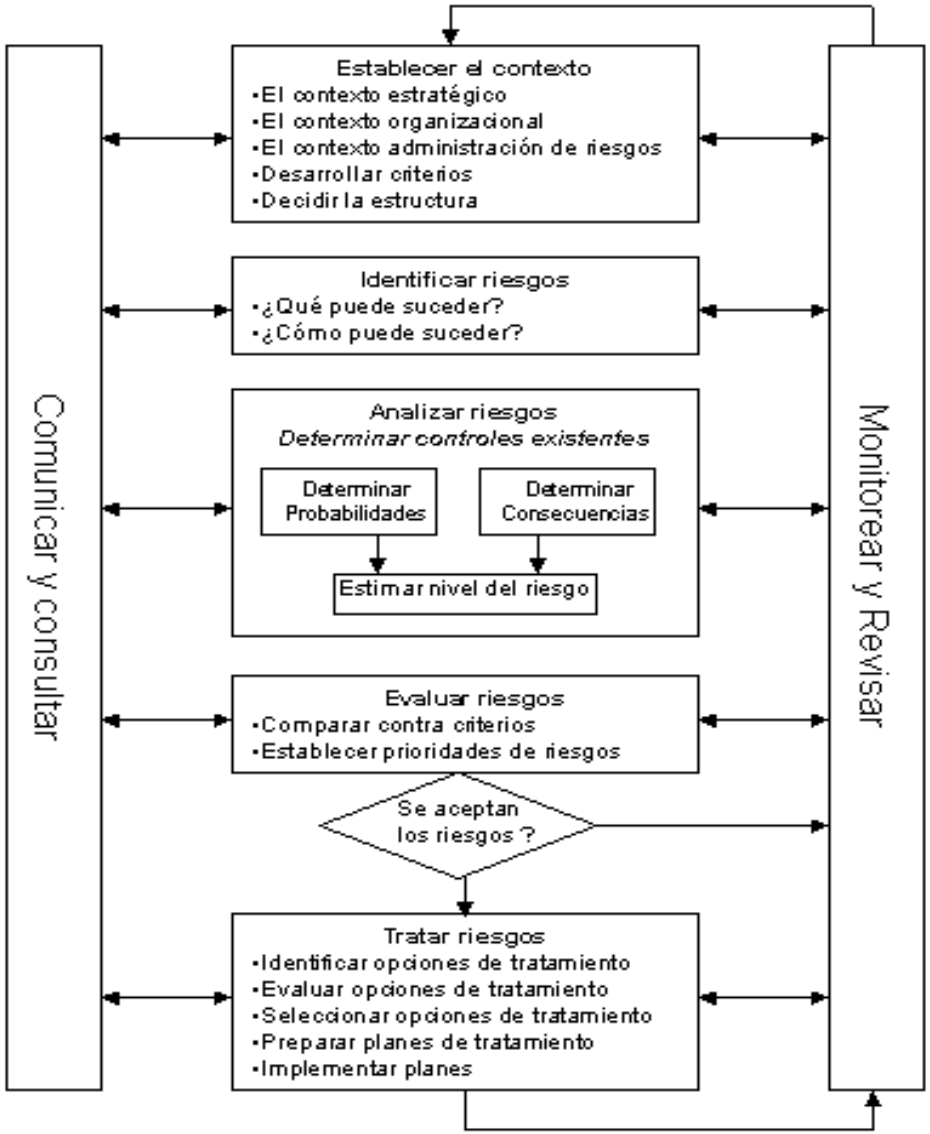
- Tiene un enfoque más amplio y explica más claramente la relación con la estrategia.
- Se sistematiza su contenido estructurándolo en 23 principios.
- Lo relaciona con la Misión y Visión de la empresa.
- La Estrategia y Riesgos se relacionan desde el proceso de planificación estratégica, su ejecución y control.
- El monitoreo toma más importancia.
- Relaciona el riesgo con la performance obtenida por la empresa en sus distintos niveles.

COSO ERM 2017



- Refuerza la accountability en los distintos niveles.
- El Apetito de Riesgo pasa a ser una parte importante y su relación con las estrategias.
- Debe relacionarse los riesgos al formular los objetivos de la empresa.
- Prioriza los riesgos.
- Enfatiza el uso de información relevante.
- Considera la evolución de las tecnologías.
- Se hace cargo de la globalización de los mercados.

Repasando el Proceso…



La familia de NORMAS ISO y su enfoque en la Gestión de Riesgos y Sistemas de Gestión

















GUÍA PRÁCTICA PARA LA INTEGRACIÓN DE COSO ERM Y SISTEMAS DE GESTIÓN ISO

Hoja de Ruta de Implementación en 6 Fases

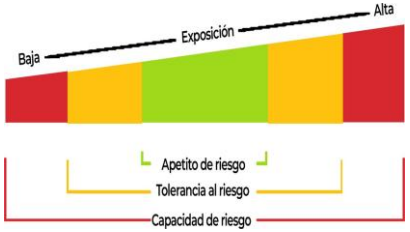
Fase 1: Compromiso de la Dirección y Gobernanza Unificada.



Fase 2: Diagnóstico y el Contexto Estratégico.



Fase 3: Definición del Apetito y Tolerancia al Riesgo.



Fase 4: Despliegue de Evaluaciones Integradas de Riesgos.



Fase 5: Tratamiento, Diseño de Controles y KPI.



Fase 6: Monitoreo, Auditoría Unificada y Reporte Ejecutivo.



Riesgos Operativos y Riesgos Financieros





Punto Crítico de Control y Puntos de Falla en Procesos



CASO PRÁCTICO INTEGRAL: EMPRESA DE GESTIÓN DE AGUA Y RESIDUOS (Eco Amigos Ambientales S.A.)




Campañas Internas de Concientización (CAP)
Campañas Internas de Concientización (CAP)

esan GRADUATE SCHOOL OF BUSINESS



CONCLUSIONES

1) La Gestión de riesgos permite proteger y crear valor dentro de una compañía para alcanzar los objetivos propuestos y mejorar su competitividad.
2) Los controles internos implementados en toda Empresa, para que sean efectivos y eficientes, deberán de ser diseñados necesariamente para reducir la probabilidad de ocurrencia e impacto de los riesgos que pueden afectar el logro de los objetivos.
3) Sólo a través de un seguimiento y monitoreo continuo del funcionamiento de los controles implementados bajo el Modelo COSO ERM, se logrará asegurar razonablemente si los mismos vienen funcionando efectivamente tal como han sido diseñados.

Mag. Mario Miguel Vergara Silva
mvergara@esan.edu.pe
Whatsapp: 991980203

PREGUNTAS

¡Gracias por su amable atención!